

Parecer técnico — Relatório de métricas da migração pós-quântica do OPIN

Sep 28, 2026 · @Manuel Matos

1. Identificação

Item	Descrição
Documento analisado	Relatório Consolidado de Métricas Experimentais: versão final — Migração pós-quântica do ecossistema OPIN: Clássico, PQC e Híbrido
Autor	Luciano Figueiredo Coelho, PPGCC/LabSEC/UFSC
Versão	Arquivo de 28/09/2026, 7 páginas
Objeto	Custo, em bytes e em tempo, de migrar o fluxo de consentimento do Open Insurance Brasil para criptografia pós-quântica (ML-DSA-65, ML-KEM-1024) e para um arranjo híbrido
Parecerista	Manuel Matos, autor independente

O parecer examina coerência metodológica, correção aritmética, alcance das conclusões e utilidade dos resultados para o planejamento regulatório. Não houve acesso aos dados brutos nem ao código do protótipo; as observações sobre tempo são inferidas dos valores publicados.

2. Síntese e veredito

Parecer favorável, com revisão antes de citação externa. O relatório tem desenho claro, aritmética correta e uma contribuição própria: o termo de certificados de CA na equação do OPINsize.

Os resultados têm maturidades distintas:

- **Tamanho (bytes):** determinísticos e independentes da máquina. Aptos à citação, com a ressalva de que o perfil PQC mantém a assinatura RSA da CA.

- **Tempo:** refletem a implementação do protótipo e o ambiente emulado. Servem para ordenar os perfis, não para estimar custo em produção.

Duas conclusões excedem os dados e devem ser reformuladas: a de que o custo pós-quântico é "fixo por fluxo" e "está no processamento, e não no transporte", e a de que a migração ocorre "sem alterar as especificações do ecossistema".

3. Pontos fortes e verificação aritmética

Todos os valores consolidados foram recalculados a partir das variáveis publicadas e conferem.

Verificação	Valor no relatório	Recálculo
OPINsize Clássico / PQC / Híbrido	75.687 / 261.663 / 340.355 bytes	Confere
Razões PQC/Clássico, Híbrido/Clássico, Híbrido/PQC	3,46× / 4,50× / 1,30×	Confere
Parcela do acréscimo do Híbrido já presente no PQC	70%	70,3%
Peso do termo de PKI no OPINsize	11,15% / 6,19% / 10,98%	Confere
Distância Híbrido-PQC sem e com o termo de PKI	23,44% → 30,07%	Confere
Saída do Diretório = $4 \times (\text{PKI_bytes} + 103)$	8.852 / 16.612 / 37.768 bytes	Confere byte a byte
Participação do RS na saída dos servidores	53,1% / 66,4% / 63,8%	Confere
Razão de T_fluxo em 0 ms e 320 ms (PQC)	3,32× e 1,11×	Confere

Três méritos merecem registro:

- **Controle de variáveis.** A estrutura do fluxo (6 conexões mTLS, 26 JWTs, 2 buscas de JWKS, 4 buscas de certificados de CA) é idêntica nos três perfis, e o grupo de troca de chave é registrado a partir da conexão real, sem recuo silencioso.
- **Extensão da equação.** O termo $N_PKI \times \text{PKI_bytes}$ corrige uma subestimativa real e é parametrizável: cada participante pode aplicar o próprio comportamento de cache.

- **Localização do custo.** Endpoints que apenas entregam chaves ou certificados não ficam mais lentos; o acréscimo aparece onde há assinatura ou verificação.

4. Questões metodológicas

As questões estão em ordem de relevância para a validade das conclusões.

4.1 Os tempos medem a implementação, não o algoritmo

Em implementações otimizadas, assinar ou verificar com ML-DSA-65 leva frações de milissegundo. No relatório, cada endpoint com assinatura fica de 10 a 25 ms mais lento, e o fluxo completo ganha 6,7 s no cenário de 0 ms.

A soma dos acréscimos medidos nos endpoints dos servidores explica cerca de 0,3 a 0,4 s dessa diferença. Os cerca de 6 s restantes estão fora dos servidores, provavelmente no cliente: assinaturas via BouncyCastle, verificação dos 26 tokens e TLS. O relatório não decompõe esse tempo.

A afirmação de que "o custo pós-quântico é fixo por fluxo" deve passar a "o custo desta implementação". Sem isso, o número de 6 a 7 segundos tende a ser citado como custo intrínseco da migração.

4.2 O modelo de latência não corresponde às 28 chamadas

Dividindo o tempo adicional de cada cenário pelo atraso emulado, o fluxo clássico acumula cerca de 129 idas e voltas a 14 ms, 143 a 30 ms e 159 a 320 ms. Com 28 requisições e 6 conexões reaproveitadas, o esperado estaria na ordem de 40.

O número efetivo é alto e cresce com o atraso. Duas hipóteses merecem verificação: o atraso incide também nos saltos internos entre gateway e servidores, ou a consulta repetida ao estado do consentimento varia com a latência. Até que se explique, os tempos absolutos, como 53,7 s no Clássico a 320 ms, não servem de referência; apenas as diferenças entre perfis são comparáveis.

4.3 A comparação PQC × Híbrido é assimétrica

No perfil PQC, os certificados do titular e das CAs têm chave ML-DSA-65, mas continuam assinados com RSA. Apenas o Híbrido carrega assinatura ML-DSA-65 da CA. O perfil PQC, portanto, não é pós-quântico de ponta a ponta, e seus certificados saem artificialmente leves.

Estimativa deste parecer, a confirmar pelo autor: com a CA assinando em ML-DSA-65 no perfil PQC, o prêmio do Híbrido sobre o PQC cairia de cerca de 30% para algo próximo de 10%. O resultado reforçaria a conclusão favorável ao Híbrido, mas contradiz a afirmação da seção 1.2 de que as comparações são justas.

4.4 Transporte e front-channel ficaram fora do alcance do ambiente

- **Banda e janela TCP.** A emulação aplica atraso sem limitar banda, em rede Docker local. Em redes móveis reais, handshakes de 16 a 18 kB podem exceder a janela inicial de congestionamento e custar idas e voltas extras. A conclusão "o custo está no processamento, e não no transporte" pode ser artefato do ambiente.
- **Cliente real.** O cliente de teste não é navegador nem aplicativo. No OPIN, parte das respostas retorna ao titular por redirecionamento, com o token no endereço (JARM). Com JWTs híbridos de 7,3 kB em média, limites de tamanho de URL e de cabeçalho em proxies, navegadores e aplicativos podem ser atingidos.

4.5 "Sem alterar as especificações" é afirmação ampla demais

A estrutura do fluxo não muda, mas o perfil de segurança do OPIN, os identificadores de algoritmo JOSE, os perfis de certificado X.509 e o diretório de participantes precisariam admitir os novos algoritmos. Isso é mudança de especificação, com custo de governança, homologação e prazo de convivência.

4.6 Questões menores

- **Unidades de medida.** JWTs são medidos serializados em base64url; a chave pública do AS, pelo tamanho bruto (256 e 1.952 bytes). Em /jwks a chave trafega codificada, cerca de um terço maior. O efeito no total é pequeno, mas a regra deve ser única.
- **Algoritmo RSA.** O Clássico usa PS256; parte dos artefatos híbridos usa RS256. Convinha alinhar ao algoritmo exigido pelo perfil de segurança do OPIN.
- **Conformidade do perfil Clássico.** A equivalência entre o perfil Clássico e o perfil de segurança vigente do OPIN deveria ser documentada, não presumida.
- **Parâmetros.** A escolha de ML-KEM-1024 e P-384 merece justificativa, já que as implantações híbridas mais difundidas usam ML-KEM-768 com X25519.
- **Modelo de certificado híbrido.** Extensões não críticas são uma entre várias abordagens; as alternativas em padronização no IETF, como assinaturas compostas, produziram tamanhos distintos.

- **Ambiente.** Máquina única com Docker Desktop em Windows 11 introduz variância de agendamento que afeta os tempos, não os bytes.

5. Recomendações ao autor

A recomendação de maior valor é incluir um quarto perfil: troca de chaves híbrida com assinaturas clássicas. O risco mais urgente para dados de seguro é a captura de tráfego hoje para decifração futura, relevante sobretudo em vida e previdência, cujos dados permanecem sensíveis por décadas. Esse risco se enfrenta migrando a troca de chaves, a parte que os próprios dados indicam ser a mais barata; assinaturas protegem a autenticidade no momento do uso e podem migrar em etapa posterior.

1. Acrescentar o perfil "KEM híbrido + assinaturas clássicas" e apresentar a migração em etapas, com custo medido em cada uma.
2. Tornar simétrica a comparação: um perfil PQC com CA assinando em ML-DSA-65, ou a declaração explícita de que o perfil PQC é de transição parcial.
3. Decompor o tempo do fluxo entre cliente, servidores, handshakes e esperas, e comparar os tempos de assinatura e verificação com referências de implementações otimizadas.
4. Explicar a contagem efetiva de idas e voltas e, se necessário, restringir o atraso emulado ao trecho entre cliente e gateway.
5. Repetir a medição de latência com limite de banda e MTU realistas, para testar se handshakes maiores geram idas e voltas adicionais.
6. Testar o front-channel com navegador e aplicativo reais, verificando limites de tamanho de URL e de cabeçalho com tokens híbridos.
7. Reformular as conclusões sobre "custo fixo por fluxo" e "sem alterar especificações" e listar as especificações do ecossistema que precisariam ser alteradas.
8. Uniformizar a unidade de medida das chaves e o algoritmo RSA entre perfis, e justificar a escolha dos parâmetros ML-KEM-1024 e P-384.

6. Conclusão

O relatório é uma das poucas medições brasileiras do custo da migração pós-quântica aplicada a uma infraestrutura regulada de dados, e sua parte de tamanho já é útil ao planejamento. Seu achado central se sustenta: o fluxo não muda de estrutura, cresce o tamanho de cada artefato, e a maior parte do custo está em deixar o clássico, não na escolha entre PQC e Híbrido.

Resultado	Condição de uso
Tamanhos e OPINsize	Citáveis, com a ressalva de que o perfil PQC mantém a assinatura RSA da CA
Equação estendida com N_PKI	Citável como contribuição metodológica
Ordem Clássico < PQC < Híbrido em tempo	Citável como resultado qualitativo
Tempos absolutos e acréscimos em segundos	Não citáveis até a decomposição do tempo e a explicação do modelo de latência
"Sem alterar as especificações"	Reformular antes de circular

Atendidas as recomendações 2, 3, 4 e 7, o trabalho estará apto a subsidiar a discussão regulatória sobre a migração pós-quântica do Open Insurance.

Manuel Matos, autor independente